

BioPrint: Behavior-Based Login Security

Hackathon technical report · v2 implementation

1. Executive summary

BioPrint is a browser-local behavioral authentication layer. It evaluates whether a login attempt behaves like the enrolled user using six interaction signals plus a separate anti-automation gate. The current implementation uses a regularized **Mahalanobis distance** rather than independent Z-scores, allowing correlations between behavioral signals to be modeled while keeping the decision lightweight and local.

2. Behavioral signals

The six-dimensional fingerprint contains mean key dwell time, mean key flight time, pointer path curvature, maximum pointer velocity, focus-transition delay, and submit-button click/hold duration. Pointer Events are used so mouse and touch-capable devices can share the collection path. Raw typed characters are not stored; only aggregate behavioral statistics are retained.

3. Enrollment

The demo uses **five natural calibration passes**. Each pass provides enough keystroke timing for a sample. The samples produce a mean vector and 6×6 covariance matrix. Because the calibration set is small, diagonal regularization is applied before matrix inversion to keep the model numerically stable.

4. Authentication algorithm

For live vector x , enrolled mean μ , and covariance Σ , BioPrint calculates the Mahalanobis distance and maps it to a 0–100 confidence score. The demonstration threshold is **70**. The dashboard exposes the distance, latency, and individual feature deviations for explainability.

Mahalanobis distance

$$D_M(x) = \sqrt{(x - \mu)^T \Sigma^{-1} (x - \mu)}$$

5. Bot and replay resistance

The pre-classification gate checks browser **isTrusted** state, near-zero flight-time variance, low timing entropy, low novelty in adjacent timing transitions, near-perfectly linear pointer paths, and suspiciously uniform pointer velocity. These signals are defense-in-depth indicators, not a formal bot-proof guarantee.

6. Adaptive baseline

Accepted, non-bot logins update the enrolled mean and covariance incrementally. Rejected and bot attempts never train the profile. This allows gradual genuine-user drift while reducing poisoning risk.

7. Chrome extension

The project includes a real Manifest V3 extension. **manifest.json** registers **content.js** as a content script for HTTP/HTTPS pages. The content script detects forms marked **data-bioprint-login**, captures interaction, reads the profile from **chrome.storage.local**, and blocks or releases the submit event. The included login page is therefore an extension test target rather than only a popup simulation.

8. Reliability evaluation

The demo contains a Reliability Lab for real labeled trials. FAR and FRR are calculated as follows:

Metric	Formula
FAR	false accepts / impostor attempts
FRR	false rejects / genuine attempts

The repository deliberately reports **no invented human FAR/FRR numbers**. For final hackathon evidence, collect at least 10 genuine and 10 impostor attempts across multiple sessions/users if possible. Automated self-tests validate software behavior but are not human reliability measurements.

9. Limitations & future work

Adversarial imitation: a determined attacker can learn interaction characteristics; stronger sequence models and active-imitation testing are future work.

Bot evasion: scripted attacks can imitate variance and trajectories; a larger dataset could support a learned sequence detector over dwell/flight ratios and pointer paths.

Cross-device generalization: keyboards, touchpads, mice, sensitivity, and context change behavior. Device-conditioned profiles or multi-device enrollment are future work.

Small-sample covariance: five passes are suitable for the demo but not a complete statistical representation of a six-dimensional distribution.

Accessibility and drift: production deployment needs accessibility-aware policies, consent/deletion controls, and carefully bounded adaptation.

10. Demo flow

1) Enroll one genuine user with five natural passes. 2) Authenticate naturally and show ACCESS GRANTED plus signal explanations. 3) Have a teammate use the same credentials with deliberately different behavior and show ACCESS DENIED. 4) Run the bot simulator or scripted attempt and show BOT DETECTED. 5) Optionally show the Reliability Lab.

BioPrint is a behavioral-risk authentication demonstration, not a standalone replacement for password security, MFA, rate limiting, or secure server-side authentication.